Xavier Sionnet

COMPTE-RENDU DE TP : TEST D'INTRUSION - PHASE I : RECONNAISSANCE ET OSINT

COMPTE-RENDU DE TP : TEST D'INTRUSION - PHASE I : RECONNAISSANCE ET OSINT
1. Introduction et Objectifs Pédagogiques
2. Configuration et Préparation de l'Environnement de Simulation
3. Étude Comparative Approfondie : Reconnaissance Passive vs Active
4. Documentation Méthodologique avec CherryTree
5. Panorama des Outils de Reconnaissance sous Kali Linux
6. Phase Pratique n°1 : Test de Connectivité et Validation Réseau (Ping)
7. Phase Pratique n°2 : Reconnaissance Avancée et OSINT avec SpiderFoot
    7.1 Initialisation et Lancement de l'Outil
    7.2 Paramétrage Avancé des Modules de Scan
    7.3 Collecte, Traitement et Analyse des Résultats
    7.4 Cas Pratique et Étude d'Impact sur la Plateforme HackerOne
8. Phase Pratique n°3 : Analyse et Cartographie d'un Serveur Web Local
9. Analyse des Risques et Bonnes Pratiques de Durcissement
10. Conclusion et Perspectives

1. Introduction et Objectifs Pédagogiques

La sécurité offensive repose sur une méthodologie stricte normée par des standards internationaux (tels que l'OSSTMM ou le PTES). L'étape préliminaire et fondatrice de tout test d'intrusion est la phase de reconnaissance (également appelée *Footprinting* ou *Reconnaissance d'empreinte*).

L'objectif de ce TP est d'apprendre à collecter, analyser et structurer l'ensemble des informations publiques ou techniques accessibles sur une cible (qu'il s'agisse d'une machine isolée ou d'une organisation) avant d'envisager la moindre tentative d'intrusion active. Cette démarche permet de :

Réduire la surface d'attaque en identifiant les points d'entrée potentiels.
Comprendre le comportement des bannières applicatives et des protocoles réseau.
Structurer de manière professionnelle les notes de manipulation afin de rédiger un rapport d'audit exploitable par une direction technique ou les équipes de remédiation.

2. Configuration et Préparation de l'Environnement de Simulation

Pour garantir l'intégrité du réseau et respecter un cadre légal et éthique, l'ensemble des manipulations est réalisé dans un environnement virtuel totalement cloisonné :

Station d'Attaque (Kali Linux) : Système d'exploitation de référence pour les auditeurs en cybersécurité, intégrant nativement des centaines d'outils d'analyse de réseau, de cartographie et d'exploitation de vulnérabilités.
Station Cible / Victime (Windows 7 SP1 Ultimate) : Machine virtuelle configurée lors des ateliers précédents (TP 2.2), volontairement exposée et maintenue sans correctifs récents pour simuler un parc informatique vulnérable au sein d'une organisation.
Isolation et topologie réseau : Les deux machines virtuelles sont connectées via un commutateur virtuel privé (mode *Host-Only* ou *Bridge* sécurisé), garantissant que le trafic de test ne transite pas vers le réseau étendu (WAN) tout en permettant des échanges de paquets IP bidirectionnels parfaits.

3. Étude Comparative Approfondie : Reconnaissance Passive vs Active

La collecte d'informations se divise en deux méthodologies aux antipodes en termes de discrétion et de volume de données recueillies :

Axe d'Analyse	Reconnaissance Passive	Reconnaissance Active
Définition technique	Investigation menée sans émettre le moindre paquet vers le système cible. L'analyste se positionne en observateur distant en exploitant exclusivement des sources ouvertes.	Investigation impliquant une interaction directe et active avec les interfaces de la cible (envoi de requêtes de sondage, de paquets TCP/UDP).
Sources d'information	Sources OSINT (*Open Source Intelligence*) : moteurs de recherche spécialisés, registres WHOIS, métadonnées de fichiers publics, réseaux sociaux professionnels, forums de développeurs.	Scanners de ports (`nmap`), outils d'énumération de services (`Nikto`, `Dirb`), requêtes de bannières applicatives, analyseurs de paquets de type *sniffers*.
Types de données extraites	Adresses e-mail professionnelles, organigrammes d'entreprise, technologies logicielles mentionnées dans des offres d'emploi, versions de CMS ou de frameworks.	Liste exhaustive des ports ouverts, fermés ou filtrés, versions exactes des services en écoute, bannières d'accueil des serveurs FTP, SSH ou HTTP.
Avantages opérationnels	Discrétion absolue : indétectable par la cible (absence totale de traces dans les journaux de connexion / *logs* de pare-feu). Potentiel d'investigation illimité.	Précision chirurgicale : permet d'obtenir l'état topologique exact et actualisé en temps réel de l'infrastructure informatique ciblée.
Inconvénients / Limites	Données parfois obsolètes, fragmentaires ou nécessitant un travail de recoupement et	Risque de détection élevé : l'envoi massif de paquets anormaux peut déclencher

Axe d'Analyse	Reconnaissance Passive	Reconnaissance Active
	de nettoyage très chronophage.	des alertes sur les systèmes de détection (IDS/IPS) ou mener à un bannissement d'adresse IP.

4. Documentation Méthodologique avec CherryTree

Durant un audit de sécurité, la quantité de données manipulées est considérable. L'utilisation d'un carnet de notes hiérarchique tel que CherryTree (installé sur l'environnement Kali Linux) s'avère indispensable pour garantir une traçabilité irréprochable.

Organisation modulaire : Le carnet de notes est structuré en arborescence logique (séparant clairement la phase de *Recon passive*, de *Recon active*, puis les sections dédiées à l'exploitation future comme *Metasploit* et *MsfVenom*).
Traçabilité des commandes : Chaque commande exécutée dans le terminal, chaque résultat de scan brut et chaque capture d'écran textuelle est immédiatement consigné dans le nœud correspondant, facilitant la rédaction ultérieure du rapport d'expertise technique.

5. Panorama des Outils de Reconnaissance sous Kali Linux

La distribution Kali Linux met à disposition un écosystème d'outils spécialisés :

Nmap (Network Mapper) : Le standard de l'industrie pour la découverte d'hôtes, le balayage de ports et l'identification fine des systèmes d'exploitation (OS Fingerprinting).
SpiderFoot : Outil d'automatisation OSINT puissant combinant l'interrogation de plus de 100 API et bases de données publiques.
Gobuster / Dirb : Utilitaires indispensables pour l'énumération de répertoires et de fichiers cachés sur les serveurs web cibles.

6. Phase Pratique n°1 : Test de Connectivité et Validation Réseau (Ping)

Avant d'engager des phases d'analyse agressive, il est primordial de valider la liaison logique entre l'attaquant et la victime.

Commande exécutée :

```shell
ping -c 4 192.168.1.50
```

Interprétation technique : L'émission de 4 requêtes de type ICMP Echo Request vers l'adresse IP de la machine Windows 7 permet de s'assurer du retour immédiat des paquets Echo Reply. Un taux de perte de 0% confirme que la couche réseau est pleinement fonctionnelle et autorise le passage aux étapes de scan approfondies.

7. Phase Pratique n°2 : Reconnaissance Avancée et OSINT avec SpiderFoot

7.1 Initialisation et Lancement de l'Outil

SpiderFoot s'exécute généralement sous forme de serveur web local au sein de l'environnement Kali. Son interface graphique permet de configurer des missions d'investigation automatisées sans nécessiter de scripts complexes.

7.2 Paramétrage Avancé des Modules de Scan

Lors de la configuration d'une nouvelle tâche, plusieurs paramètres sont ajustés :

Target Specification : Saisie du domaine cible ou de l'adresse IP à auditer.
Use case / Scans profile : Sélection des modules (ex: recherche de foot-prints DNS, extraction de métadonnées de documents, recherche d'adresses e-mail compromises dans des bases publiques).

7.3 Collecte, Traitement et Analyse des Résultats

Le moteur exécute les modules de manière asynchrone. L'interface synthétise les corrélations sous forme de graphiques et de tableaux catégorisés, mettant en lumière des informations sensibles qui n'auraient pu être devinées manuellement (sous-domaines oubliés, certificats expirés, configurations de serveurs de messagerie mal sécurisées).

7.4 Cas Pratique et Étude d'Impact sur la Plateforme HackerOne

L'exercice pratique d'entraînement a consisté à analyser un domaine public d'évaluation (comme la plateforme *HackerOne*). Cette simulation à grande échelle démontre qu'une structure informatique expose toujours une quantité massive d'informations tierces (fournisseurs cloud, technologies d'hébergement, réseaux sociaux d'employés) facilitant l'ingénierie sociale ou l'identification de failles applicatives en amont d'un audit formel.

8. Phase Pratique n°3 : Analyse et Cartographie d'un Serveur Web Local

L'exercice final de cette séquence a consisté à réaliser un audit de services ciblés sur le réseau local de test :

Analyse des bannières applicatives des services HTTP/FTP en écoute sur la machine victime.
Consignation minutieuse des versions logicielles identifiées (par exemple, des versions obsolètes de serveurs web ou de services de partage de fichiers), qui constitueront la cible principale des modules d'exploitation lors des prochains travaux pratiques.

9. Analyse des Risques et Bonnes Pratiques de Durcissement

Les observations menées durant ce TP mettent en évidence plusieurs vulnérabilités organisationnelles et techniques :

Exposition excessive d'informations : L'utilisation imprudente de métadonnées dans les fichiers d'entreprise ou la publication de détails techniques sur les forums d'assistance offre aux attaquants des vecteurs de reconnaissance passive redoutables.
Défaut de cloisonnement réseau : L'absence de segmentation stricte entre les postes utilisateurs et les serveurs critiques accentue le risque de propagation latérale en cas de compromission initiale.
Recommandations de sécurité : Mettre en place des politiques strictes de minimisation des données exposées en ligne, auditer régulièrement la surface d'attaque externe et durcir les services réseau en désactivant systématiquement les bannières applicatives verbeuses.

10. Conclusion et Perspectives

Ce TP 2.3 constitue une fondation indispensable dans le parcours de spécialisation en cybersécurité du BTS SIO. Il démontre que la réussite d'un test d'intrusion ne repose pas uniquement sur l'utilisation d'exploits automatisés, mais avant tout sur une phase d'investigation, de recherche (OSINT) et de documentation rigoureuse (CherryTree). La machine virtuelle Windows 7 SP1, désormais cartographiée et documentée, est prête à faire l'objet d'une phase d'analyse de vulnérabilités approfondie et d'exploitation contrôlée lors des ateliers suivants.